

Computer and Network Security — Lecture 04

Dr. Karim Lounis

Jan - Jun 2026



Fundamental Security Services

Fundamental Security Services

Definition

Security Services. Services provided through security mechanisms to protect information systems and make them resilient against attacks.

We define the following fundamental security services (or goals):

- Authentication.
- Confidentiality.
- Integrity.
- Availability.
- Non-repudiation.



You may find, in the literature, that some authors differently define the set of fundamental security services (e.g., may add authorization).

Attack Categorization

We have seen that attacks can be categorized into active and passive:

Active Attacks. These attacks aim to alter and breach the authenticity, integrity, availability, and confidentiality of information systems.

Passive Attacks. These attacks aim to breach the confidentiality by collecting and gaining information about the target information system.

Or categorized into inside or outside attacks:

Inside Attacks. These attacks originate from within the security perimeter of the system. It is usually caused by an “insider” who uses its privileges to harm the system (e.g., dishonest employee or contractor).

Outside Attacks. These attacks originate from outside the information system, e.g., Internet or a remote access connection.

We can classify them further using Stallings' classification: **Interruption, Interception, Modification, and Fabrication.** (outdated though)

Fundamental Security Services

Definition

Security Services. Services provided through security mechanisms to secure information systems and make them resilient against attacks.

Authentication. Prove your identity: What you know/have/are (and where u r)?

Confidentiality. Protect information from being disclosed to unauthorized parties.

Integrity. Protect information from being modified while being stored or transferred.

Availability. Guarantee that information system resources are available at all time.

Non-repudiation. Nobody denies having done (i.e., executed, sent, received, deleted, created, logged on/out, modified, ...) something in the system.

In the literature, you will find the CIA triad: Confidentiality, Integrity, and Availability. The services of authentication and non-repudiation were added later on.

Others: Authorization, Privacy, Trust, Anonymity, ..., Accountability.

Fundamental Security Services (Authentication)

- ① **Authentication.** It aims at proving and verifying the identities of entities involved in a system (not to be confused with identification).



*"This site wants a two-factor authentication.
A retina scan and **blood** sample."*

This is one of the most important, if not the most important, security service.

Fundamental Security Services (Authentication)

- ① **Authentication.** It aims at proving and verifying the identities of entities involved in a system (not to be confused with identification).

There are two authentication aspects:

- **Entity authentication** (prove that you are who you are)

Provides assurance that a concerned identity is as asserted

- **Data origin authentication** (prove that it really came from you)

Provides assurance that the source of data (or software) is as asserted.

Authentication is usually a one-to-one process, whereas identification is a one-to-many process.

Fundamental Security Services (Authentication)

Authentication can be implemented using various ways:

- **Knowledge-based Authentication.** Asks the user about information that they only should know. E.g., password, passphrase, PIN code, or answer pre-defined security questions (i.e., what you know).
- **Biometric and Hardware Authentication.** Ask the user about unique physical traits or behavioral patterns. E.g., fingerprints, facial and voice recognition, keystrokes and mouse movements (i.e., what you are + what you do).
- **Physical Authenticator.** Ask the user to use a physical token (OTP device), USB dongle, or a smart card that they only should hold (i.e., what you have).
- **Location-based Authentication.** Proves that an assumed entity is indeed within a certain premises (i.e., where you are).

Cryptography. Is a very strong mathematical tool to enforce authentication. Mechanisms such as digital signature, keyed-hash functions, and secret keys can be used to allow authentication of entities and source of origine.

Fundamental Security Services (Authentication)

Authentication can be implemented using various ways:

Password-based Authentication:

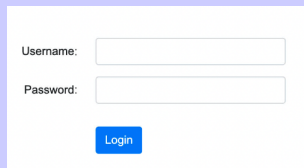
It consists of using a secret password (or passphrase) along with a username (or userId) to “prove” one’s identity.

An easy but weak means of authentication (dominant). Can be defeated using various ways.

A correct password does not ensure that whoever entered it, is the authorized user (e.g., lucky guess).

Usually stored in cleartext or hashed in a file (e.g., `/etc/shadow`).

Passwords may adhere to various rules and policies (e.g., LUDS) to increase their strength (e.g., `X=ensia@AI2023+2024`).



A login form with two input fields and a button. The first field is labeled 'Username:' and the second is labeled 'Password:'. Below the fields is a blue button with the text 'Login'.

Fundamental Security Services (Authentication)

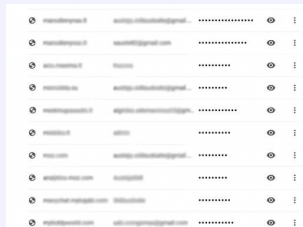
Authentication

Password Managers: (Improving Usability)

Passwords concentrator software utilities that allow protected storage and retrieval of passwords on demand, using one single “master password”.

Two approaches are used:
(1) Password wallet & (2)
Derived passwords.

They come as: an OS utility (e.g., macOS Keychain), a stand-alone app (e.g., MS Authenticator), browser built-in module, a cloud-based service (e.g., 1Password).



Passwords may adhere to various rules and policies (e.g., LIDS) to increase their strength (e.g., X=ensia@AI2023+2024).

Exercise

Think about various attack scenarios to maliciously learn the password for an account, and then propose countermeasures that can be applied to thwart most of those attack scenarios.

Exercise (Discussed Solution)

Think about various scenarios to maliciously learn the password for an account and propose countermeasures for each scenario.

Attack Scenarios:

- Online password guessing.
- Offline password guessing.
- Password capturing (network).
- Social-engineering (technical & physical).
- Password interface bypass.
- Password recovery questions or means.
- ...

Exercise (Discussed Solution)

Think about various scenarios to maliciously learn the password for an account and propose countermeasures for each scenario.

Countermeasures:

- LUDS policy.
- Passphrases instead of passwords.
- Password expiration policy.
- Rate-limit for online guessing.
- Iterated hashing (password stretching — slow hashing).
- Password salting and secret salting (pepper).
- Denylisting of passwords (denylist).
- Proactive password checking.

Check NIST SP 800-63B for more information

Fundamental Security Services (Authentication)

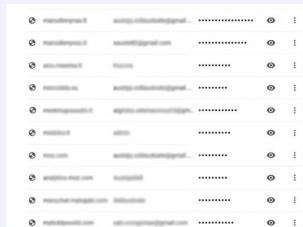
Authentication

Password Managers: (Improving Usability)

Passwords Passwords concentrator software utilities that allow protected storage and retrieval of passwords on demand, using one single “master password”.

Two approaches are used:
(1) Password wallet & (2)
Derived passwords.

They come as: an OS utility (e.g., macOS Keychain), a stand-alone app (e.g., MS Authenticator), browser built-in module, a cloud-based service (e.g., 1Password).



username@	http://localhost/		ⓧ	⋮
username@	localhost/		ⓧ	⋮
username@	http://		ⓧ	⋮
username@	http://localhost/		ⓧ	⋮
username@	http://localhost/		ⓧ	⋮
username@	http://localhost/		ⓧ	⋮
username@	http://localhost/		ⓧ	⋮
username@	http://localhost/		ⓧ	⋮
username@	http://localhost/		ⓧ	⋮
username@	http://localhost/		ⓧ	⋮

Passwords may adhere to various rules and policies (e.g., LIDS) to increase their strength (e.g., X=ensia@AI2023+2024).

Fundamental Security Services (Authentication)

Authen

Graphical-passwords: (Improving Usability)

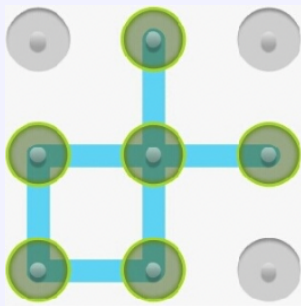
Instead of text, graphical password-based authentication uses patterns and pictures for authentication.

Human memory is better for pictures than text.

The graphical password is encoded into a string against which verification is performed.

Three basic approaches:

- (1) Pure recall (Android),
- (2) Cued recall, and (3) Recognition scheme.



to increase their strength (e.g., X=ensia@AI2023+2024).

Fundamental Security Services (Authentication)

Authentication

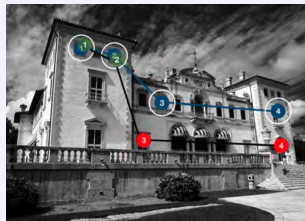
Graphical-passwords: (Improving Usability)

Instead of text, graphical password-based authentication uses patterns and pictures for authentication.

Human memory is better for pictures than text.

The graphical password is encoded into a string against which verification is performed.

Three basic approaches: (1) Pure recall (Android), (2) Cued recall, and (3) Recognition scheme.



Passwords may adhere to various rules and policies (e.g., LUDS) to increase their strength (e.g., X=ensia@AI2023+2024).

Fundamental Security Services (Authentication)

Authentication

Graphical-passwords: (Improving Usability)

Instead of text, graphical password-based authentication uses patterns and pictures for authentication.

Human memory is better for pictures than text.

The graphical password is encoded into a string against which verification is performed.

Three basic approaches:

- (1) Pure recall (Android),
- (2) Cued recall, and (3) Recognition scheme.



Pass

It co
with

An e

thent

defea

A co

sure t

autho

Usua

Passw

to increase their strength (e.g., X=ensia@AI2023+2024).

at

along ty

ntity.

hys-

n,

e),

).)

ed

n.

an

ow).

an

IDS)

999

/ 44

Fundamental Security Services (Authentication)

Authentication can be implemented using various ways:

OTP-based Authentication:

It consists of using a device (or dedicated software) that generates a random number — a password valid for one use only.

Sometimes, comes as a paper list of passwords or numbers (Banks).

Used shared secret and time-stamps with hash function to generate a 60' valid 4/6-digit number.

Used by some services for authentication and account recovery (OTPs received by modile-phone).

Can be defeated using pre-play attack or SIM swap attack (both require social engineering).



Fundamental Security Services (Authentication)

Authentication can be implemented using various ways:

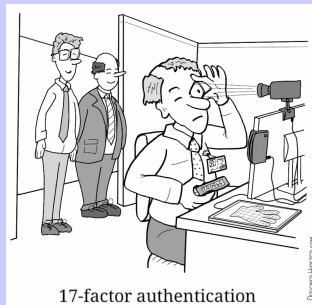
Multi-factor Authentication:

It consists of using a combination of two or more authentication means to successfully complete the authentication process.

Motivation is: different authentication categories are more likely to deliver independent protection.

This motivational principal can be broken if advisory rules are neglected (e.g., writing your PIN code on your bank/CCP card).

In its simplest form, 2FA.



Fundamental Security Services (Authentication)

Authentication can be implemented using various ways:

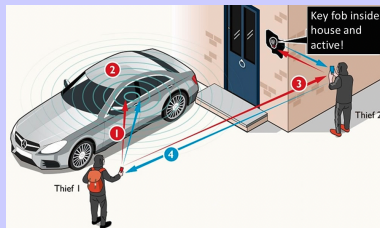
Multi-signal Authentication:

It consists of using a combination of two or more authentication means to successfully complete the authentication process.

Unlike multi-factor, multi-signal uses “invisible” authentication checks behind the scenes.

Signals include: IP addresses, browser cookies, device fingerprints (PUFs), and proximity.

Provide better usability compared to multi-factor (Contactless).



Fundamental Security Services (Authentication)

Authentication can be implemented using various ways:

Biometric-based Authentication:

It consists of using certain human characteristics (physical and behavioral) that are unique to individuals to prove one's identity.

Unlike password-based schemes, passwords are secret, biometrics schemes use non-secret features.

It is generally not suitable for remote authentication (Internet).

A two-stage authentication is generally used: user-to-phone (using biometrics) then phone-to-site (using protocols).

Requires additional hardware, reuse has severe consequences, ...



Fundamental Security Services (Authentication)

A Single Sign-On Authentication:

This consists of authenticating using a third-party account (a.k.a., social login). It allows users to access multiple webservices using credentials from a single identity provider (limited access).

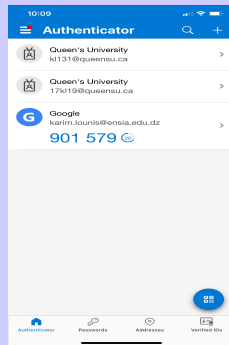
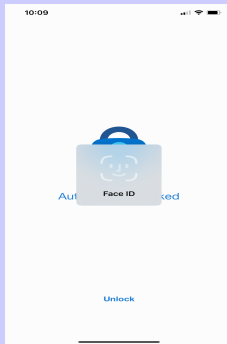
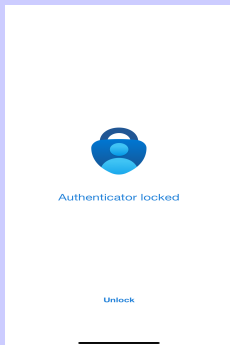
The image displays two side-by-side login forms. The left form is for Overleaf, featuring the Overleaf logo at the top. Below the logo, it says 'Log in to Overleaf'. There are three buttons for social login: 'Log in with Google' (with the Google logo), 'Log in with ORCID' (with the ORCID logo), and 'Log in with IEEE' (with the IEEE logo). Below these is a link 'Log in with Twitter ...'. At the bottom, there are fields for 'Email' and 'Password', and a green 'Log in' button. The right form is for ORCID ID, featuring the ORCID logo at the top. Below the logo, it says 'Sign in to ORCID'. There is a text input field for 'Email or 16-digit ORCID ID' with the example 'example@email.com or 0000-0001-2345-6789'. Below this is a 'Password' field and a blue 'SIGN IN' button. There are links for 'Forgot your password or ORCID ID?' and 'Don't have an ORCID ID yet? Register now'. At the bottom, there is a section 'Access through your Institution' with a button for 'Sign in with Google' and a button for 'Sign in with Facebook'.

Uses protocols such as: OAuth, OpenID Connect, and SAML.

Fundamental Security Services (Authentication)

A Authenticator apps:

These are multi-factor authentication tools (e.g., Microsoft Authenticator, Google Authenticator, etc). They generate time-based passwords (TOTPs), or push notifications to verify a user's identity during login attempts.



Fundamental Security Services (Authentication)

Authentication can be implemented using various ways:

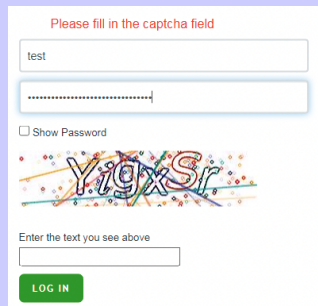
CAPTCHAs: (could be a “something you are”)

The “Completely Automated Public Turing test to tell Computers and Humans Apart” (2000), allows to perform a turing-test, that is relatively easy for a human, but difficult for computer programs.

A security measure to prevent DoS behaviors (bulk data acquisition, bulky posting, spamming, ...)

Uses character recognition (CR), audio recognition (AUD), image recognition (IR), or cognitive challenges involving puzzles (COG).

Google reCAPTCHA and “I’m not a robot”.



Fundamental Security Services (Confidentiality)

- ② **Confidentiality.** This service aims to protect information from being disclosed to unauthorized entities.



Non-public information accessible only to authorized parties.

Fundamental Security Services (Confidentiality)

Confidentiality can be implemented using various ways:

- **Steganography.** It is a method where information can be hidden and encoded within an image, audio, text, or video.
- **Cryptography.** Cryptography provides the mechanism of encyrption where readable information is transformed (encrypted) into unreadable format using secret information (a key — does not need to be shared).
- **Access Control.** This measure allows to define who is allowed and who is not allowed to access some particular information.
- **Physical Security.** Physical security measures are sometimes used to keep information confidential, and only accessible to authorized parties.
- **Cover Channels.** Is a techniques of hidding and embedding sensitive information within seemingly innocuous communication flows (e.g., use reserved bits).

Fundamental Security Services (Confidentiality)

Confidentiality Is not Privacy: (TRESPASS)

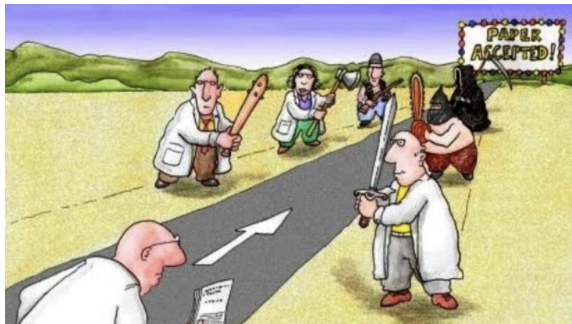
Confidentiality Is not Privacy: (TRESPASS)

Privacy concerns people (and what they consider private + what is asserted to be private — private properties), whereas confidentiality concerns the secrecy of data. Privacy deals with (but not limited to):

- Methods used to identify people (he, she, they, Mr, Ms, Mrs, Dr., Prof., ...).
- Settings in which an individual appear to the public.
- Methods used to obtain information about people.
- Methods used to process information about people.
- Nature of the information (shared Vs $\neg$ shared).

Fundamental Security Services (Integrity)

- ③ **Integrity.** This service allows to verify and to guarantee that information had not been modified or tampered-with in an unauthorized or unintended manner while being stored (at rest), transmitted (in motion), or processed.



This holds for all types of resources. I.e., logical integrity, hardware integrity, and social integrity (e.g., bribery, blackmail, coercion...).

Fundamental Security Services (Integrity)

Integrity can be implemented using various ways:

- **Cryptography.** We apply hashing functions to produce unique values from files and messages (MIC: Message Integrity Code). This code is then used to verify whether the hashed content was unintentionally changed later on.
- **Physical Security.** Physical security measures are sometimes adopted to keep information and resources safe and secure from unauthorized entities and malicious activities. The Integrity of the protected resources is preserved.
- **Access Control and Authentication.** Restrict access to information using access controls and ensure that only authorized individuals or processes can modify it. E.g., MAC (Message Authentication Code), and HMAC.
- **Logging and Auditing.** Maintain detailed logs of data access, modifications, and events. Regularly review logs for any suspicious activity.

Fundamental Security Services (Availability)

- ④ **Availability.** Is assures that the resources remain available when-ever requested. This service, along with the previous one, become very crucial and critical when it comes to the Internet of Things.



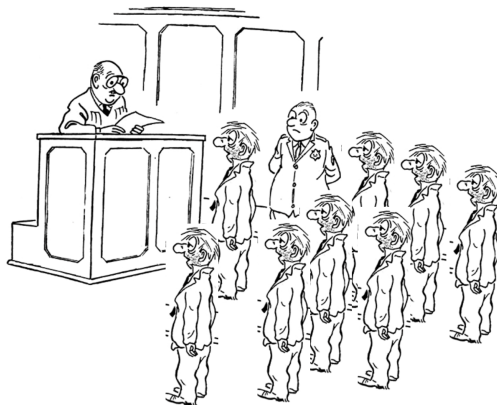
Fundamental Security Services (Availability)

Availability can be enforced using various ways:

- **Resource Duplication.** Make the same resource available at different location and time. Also, have a load testing and capacity planning ready to be used when necessary.
- **Authentication.** Guaranteeing authentication, in many cases, secures availability. Yet, too much authentication, may impact availability.
- **Software and Hardware Solutions.** Tools such as anti-malware, firewalls, and IDSs, are used to mitigate attacks against availability.
- **Physical Security.** Physical security measures are sometimes adopted to keep resources available for their users.

Fundamental Security Services (Non-Repudiation)

- ⑤ **Non-Repudiation.** This service ensures that parties involved in a digital transaction cannot deny their involvement or actions.



Fundamental Security Services (Non-Repudiation)

Non-repudiation can be enforced using various ways:

- **Cryptography.** Cryptography provides the mechanism of digital signature that can only be generated by one and only one particular party on a digital content.
- **Biometric Authentication.** Biometric traits can be used as unique fingerprints associated to their holder's activities.
- **Hardware Authentication.** Some integrated circuits come with a special purpose part, called PUF (Physical Unclonable Function), that can be used to generate a digital fingerprint.
- **Trusted Third Parties and Notaries.** Involves trusted third-party services or notaries to validate and record transactions, providing an external authority to confirm the transaction's authenticity.

Other Security Services

In addition to the fundamental security services, there are other important security services:

- **Authorization.** Is the property of controlling access to computer resources by approved entities. It is achieved through access control mechanisms. E.g.,

```
#chmod 700 secret_document.pdf
```

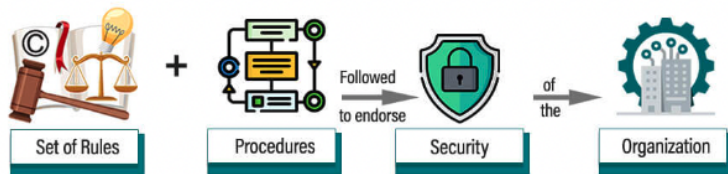
- **Accountability.** Expresses the ability to identify entities responsible for past actions. This is achieved by transaction evidence or recorded logs.
- **Anonymity.** Is the property that one's actions or involvement are not linkable to a public identity (use of dedicated protocols or forward proxies — VPNs).
- **Privacy.** Deals with the protection of personally sensitive information and controls how it is shared (phone number, home address, religion, health, ...).
- **Trust and Trustworthiness.** Something is trustworthy if it deserves our confidence, whereas something trusted has our confidence.

Security Policies

Security Policies (ISO27001)

Definition

Security Policy. It is a set of explicit rules (an internal document) that specify what the users are allowed to do, and what they are not allowed to do in a institution's IT system. It specifies what the users undergo (e.g., logging, surveillance, ...), the procedures to access and manage IT services (e.g., MFA), and how to deal and act during a security threat.

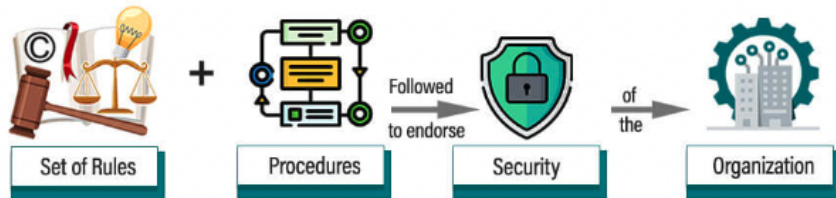


Generally, an institution sets up a security policy when it employs hundreds of individuals and operates on a sensitive sector.

Security Policies (All about Rules and Practices)

There are two way to establish security policies when it comes to setting up rules: Allow-all-then-deny or Deny-all-then-allow.

Setting up a security policy is based on **risk analysis** (various methodologies: ISO31000, MEHARI, EBIOS, NIST RMF, Octave, ...).

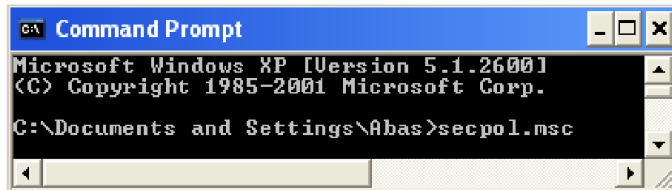


It is different from the internal rules (working time, absences, contract, dressing, hygiene, area and facilities utilization, code of conduct, ...), and from IT charts (rules and condition to use IT infrastructure, and the consequences of not following the rules — legally-bound document).

Local Security Policies (E.g., Windows machines)

On Windows machines, you can define and configure a local security policy to manage security among several user accounts.

Use the `secpol` utility:



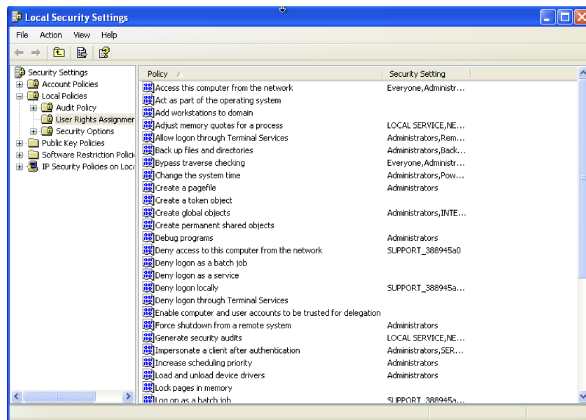
It allows the administrator to set up security rules as per access to resources, execution of commands, logging of events, ...

You can define rules for the used passwords, internet access, login time, account lifetime, ...

Local Security Policies (E.g., Windows machines)

On Windows machines, you can define and configure a local security policy to manage security among several user accounts.

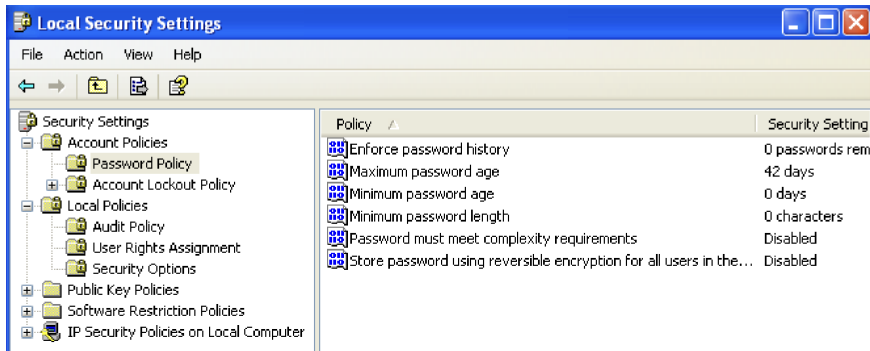
Use the `secpol` utility:



Local Security Policies (E.g., Windows machines)

On Windows machines, you can define and configure a local security policy to manage security among several user accounts.

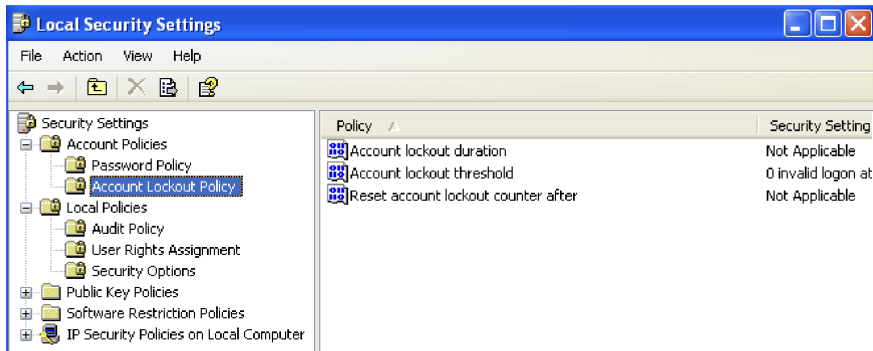
Use the `secpol` utility:



Local Security Policies (E.g., Windows machines)

On Windows machines, you can define and configure a local security policy to manage security among several user accounts.

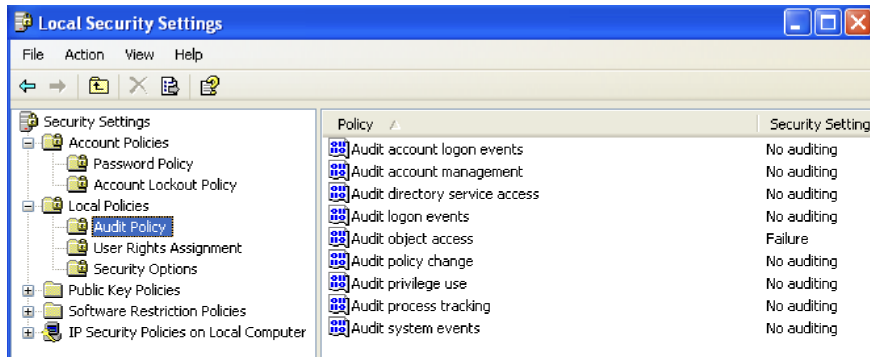
Use the `secpol` utility:



Local Security Policies (E.g., Windows machines)

On Windows machines, you can define and configure a local security policy to manage security among several user accounts.

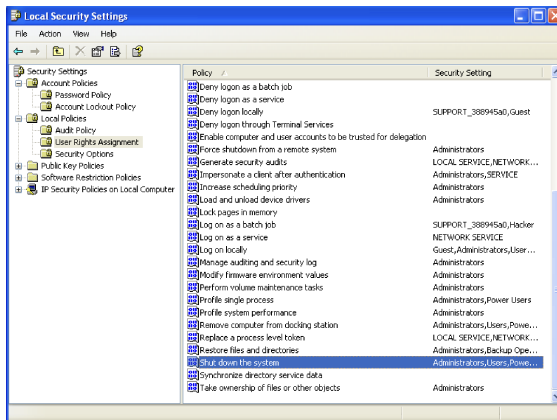
Use the `secpol` utility:



Local Security Policies (E.g., Windows machines)

On Windows machines, you can define and configure a local security policy to manage security among several user accounts.

Use the `secpol` utility:



- **End.**